tuli — Security roadmap

tulidocs.com · Prepared 12 October 2026 · Tick items off as they ship

Should add before or soon after launch

Recommended order: 1–2 (one email provider covers both), then 5–7 (quick server and nginx wins), then 3–4.

#	Item	Priority	Effort	Done / date
1	**Password reset by email** There's currently no "forgot password", so a user who forgets theirs is stuck. This needs an email provider (Resend, Postmark, Mailgun or similar).	High	1–2 days	☐ _____
2	**Email verification at sign-up** Stops fake sign-ups and makes sure the reset email reaches the real owner.	High	1 day	☐ _____
3	**"Log out everywhere" and session revocation** Changing a password should sign out all other devices. Today a stolen session cookie stays valid until it expires, which is 30 days.	High	1 day	☐ _____
4	**Account lockout and alerts** After repeated failed logins, add a short lockout per account, not just per address, and email the owner about a new sign-in.	Medium	1 day	☐ _____
5	**Security headers on the website itself** nginx should send HSTS (HTTPS only), a Content-Security-Policy limiting which scripts can run (your own plus Paystack), and frame protection. These are a few lines in the nginx config.	High	1 hour	☐ _____
6	**Server hardening (shared with your other apps)** SSH keys only, password login off, a firewall (`ufw`) allowing only 22, 80 and 443, `fail2ban`, and automatic security updates. Postgres and Redis listen only on 127.0.0.1; worth confirming.	High	2 hours	☐ _____
7	**Daily encrypted database backups, kept off the server** Plus one test restore. This protects you against loss and ransomware as much as against attacks.	High	Half a day	☐ _____

Next stage — especially for business customers and the API

#	Item	Priority	Effort	Done / date
8	**Two-factor sign-in (authenticator app)** Optional at first and encouraged for admins.	Medium	2 days	☐ _____

#	Item	Priority	Effort	Done / date
9	**Activity log** Who created, edited or deleted documents, changed settings or paid, with time and address. Businesses ask for this, and it helps with support disputes.	Medium	2 days	☐ _____
10	**Team roles** Once several staff share an account: for example, a staff member who can create invoices but not change billing or delete documents.	Medium	3 days	☐ _____
11	**API keys (if you build the API)** Stored hashed, shown only once, each limited to what it's allowed to do, revocable, with usage limits per key. Signed webhooks.	With API	2 days	☐ _____
12	**Dependency and secret hygiene** Automatic alerts for vulnerable packages (`npm audit`, GitHub Dependabot), secret scanning on the repo, and changing keys when someone leaves.	Medium	2 hours	☐ _____
13	**Privacy basics** A privacy policy, a "download my data" option, and account deletion. Kenya's Data Protection Act expects these, and so do customers. **Privacy policy and terms: done (12 Oct 2026).** Still to build: data download and account deletion.	High	1–2 days	☐ _____

Already in place

- ✓ Passwords hashed with bcrypt; session in an httpOnly, secure, sameSite cookie
- ✓ Rate limiting (Redis) on login, sign-up, payments and feedback
- ✓ Each business only sees its own data; admin-only actions role-checked
- ✓ Payments verified with Paystack; webhook signatures, amount and currency checked
- ✓ Watermark baked in on the server; PDF rendering has outside network blocked
- ✓ Logos: PNG/JPEG/WebP only, max 400 KB (SVG rejected)
- ✓ Security headers on the API (helmet), CORS, input validation on every request
- ✓ API refuses to start with a weak secret or mock payments in production